



A TRUSTARCHIVE WHITE PAPER

The Cloud Liability Problem in Trust Administration

Why storing client trust data in cloud software creates undisclosed fiduciary exposure — and what a local-first architecture does about it

A White Paper for Estate Attorneys, Trust CPAs, Corporate Trustees, and Independent Fiduciaries

What Is In This Paper

This paper is in two parts. Part One states the problem and the authority behind it. Part Two shows how one architecture answers it. Read Part One even if you never evaluate TrustArchive — the exposure it describes applies to whatever software you use today.

PART ONE · THE EXPOSURE

- 1 The Fiduciary Duty of Confidentiality
- 2 The Professional Responsibility Overlay
- 3 Four Risks You Are Probably Not Managing
- 4 "Secure Cloud" Is Not the Same as "Private"
- 5 The Market Is Moving Toward More Exposure

PART TWO · THE ANSWER

- 6 A Different Architecture
- 7 Risk by Risk: What Changes
- 8 Defensibility: The Fiduciary Record
- 9 The Cryptographic Audit Trail
- 10 An Assistant That Never Phones Home
- 11 What Is In the Application
- 12 What TrustArchive Does Not Do
- 13 What Professional Trustees Should Do Now

A NOTE ON SOURCING

Every factual and legal claim in this paper is footnoted to a primary or authoritative secondary source, listed in Notes and Sources at the end. Where an argument is analogical rather than settled law — as it is on whether cloud storage breaches a trustee's duty of confidentiality — this paper says so plainly rather than overstating it.

The Hidden Risk in Your Technology Stack

Most professional trustees — estate attorneys, CPAs, and trust companies — have adopted cloud-based practice management and trust accounting software without examining a specific question: does storing client trust data in a third-party cloud system create an obligation you have never disclosed to your clients?

The honest answer is that no court has ruled on it. That is precisely the problem. You are operating in an area where the duties are well established, the technology is new, the disclosure practices have not caught up, and the first trustee to be tested on it will be tested in hindsight.

What is well established is this. A trustee's duty of loyalty carries with it a duty to preserve the confidentiality of trust information from third persons.⁴ A trustee who engages an agent must use reasonable care in selecting that agent and monitoring its work.³ A lawyer must make reasonable efforts to prevent unauthorized access to client information and is responsible for the conduct of the nonlawyer vendors they retain.⁶ None of those duties were suspended when the software industry moved to the cloud.

This paper examines four exposures that follow from that mismatch: vendor personnel access you cannot audit, legal process served on your vendor rather than on you, vendor failure on a timeline far shorter than your record-retention obligation, and engagement letters that never addressed data storage at all. It then examines why SOC 2 certification does not resolve any of them, and why the direction the trust software market is currently moving — consolidation, cloud migration, and cloud AI features layered onto existing products — increases these exposures rather than reducing them.

Part Two describes a different architecture: local-first software in which the trust database lives encrypted on the fiduciary's own machine, the vendor holds no readable copy, and the AI assistant runs on the device rather than in someone else's data center. This paper is not an argument against technology. It is an argument for knowing exactly what your technology does with your clients' most sensitive information, and being able to explain that choice to a beneficiary, a judge, or a bar investigator.

Three Figures Worth Sitting With

~75%

of attorneys report using cloud computing for work²

<30%

report reviewing their cloud vendor's terms or privacy policy²

\$10.22M

average cost of a U.S. data breach in 2025 — an all-time high¹

THE QUESTION THIS PAPER IS BUILT AROUND

Does your current engagement letter or client disclosure explicitly tell clients that their trust data — beneficiary records, asset schedules, distribution history — is stored on third-party servers you do not control, cannot audit, and cannot prevent from receiving legal process?

If the answer is no, the remainder of this paper is about the gap between what you have disclosed and what is actually happening to that data.

The Fiduciary Duty of Confidentiality

The trustee's duty of confidentiality is not a professional courtesy. It is an incident of the duty of loyalty. The Restatement (Third) of Trusts states it directly: incident to the duty of loyalty is the trustee's duty to preserve the confidentiality and privacy of trust information from disclosure to third persons, except as required by law or as necessary or appropriate to proper administration.⁴

The Uniform Trust Code — adopted in some form by 36 states and the District of Columbia⁵ — does not contain a standalone confidentiality section. It does not need to. The relevant duties are distributed across several sections that, taken together, govern how a trustee handles trust information and the agents who touch it.

AUTHORITY	DUTY	WHY IT MATTERS TO YOUR SOFTWARE
UTC § 802	Duty of loyalty	The doctrinal home of confidentiality. Trust information is administered solely in the beneficiaries' interest.
UTC § 804	Prudent administration	Requires reasonable care, skill, and caution — including in the systems chosen to hold trust records.
UTC § 807	Delegation to agents	Reasonable care in selecting an agent, defining scope, and monitoring performance. A vendor holding your trust data is an agent in function, whatever the contract calls it.
UTC § 810	Recordkeeping	A trustee shall keep adequate records of the administration of the trust.
UTC § 813	Duty to inform and report	Qualified beneficiaries must be kept reasonably informed about the administration and material facts.
Restatement (Third) §§ 78, 83	Confidentiality; clear accounts	Confidentiality flows from loyalty; accounts must be clear, accurate, and renderable on demand.

What the duty actually covers

The confidential category is broader than most technology decisions assume. It includes:

- Beneficiary identities, contact information, and financial circumstances
- Distribution history, amounts, and character — income versus principal
- Trust asset values, ownership structures, and cost basis information
- Family relationships, disputes, incapacity, and special needs considerations
- The existence of discretionary authority and the record of how it has been exercised

Every item on that list is routinely stored in cloud trust administration software. The question professional trustees rarely ask is who else can reach it, under what circumstances, and whether the client has been told.

Where the argument is settled and where it is not

This paper takes a deliberately narrow position, because the broad version is not defensible. No reported decision holds that a trustee breaches the duty of confidentiality by using cloud software. The question has not been litigated to a holding. Anyone telling you otherwise is selling something.

The defensible position is narrower and, for planning purposes, more useful: the duties above were written for a world where records sat in a trustee's own file room, and they have not been re-examined in light of software that transmits those records to infrastructure the trustee neither owns nor can inspect. The exposure is not that you have already breached a duty. It is that you have accepted an undisclosed risk on your client's behalf, you did not document the decision, and the standard by which it will eventually be judged does not exist yet.

The Professional Responsibility Overlay

For the attorneys and CPAs in this audience, the trust-law duties are only half the picture. The rules of professional conduct impose a parallel, and in some respects more concrete, set of obligations about technology and third-party vendors.

The three rules that govern vendor choice

- **Model Rule 1.1, Comment 8** — competence includes keeping abreast of the benefits and risks associated with relevant technology. As of 2026, 40 states plus the District of Columbia and Puerto Rico have adopted this duty of technology competence.¹²
- **Model Rule 1.6(c)** — a lawyer shall make reasonable efforts to prevent the inadvertent or unauthorized disclosure of, or unauthorized access to, information relating to the representation.⁶
- **Model Rule 5.3** — the supervisory duty over nonlawyer assistance extends to outside vendors, including cloud providers.⁶

The ABA has applied these rules to technology repeatedly and specifically. Formal Opinion 477R (2017) requires a fact-specific security analysis rather than a blanket assumption of safety.⁷ Formal Opinion 483 (2018) addresses obligations after a data breach.⁸ Formal Opinion 498 (2021) confirms that Rules 1.6 and 5.3 apply to the cloud vendors a virtual practice relies on.⁹ Thirty states have issued formal or informal ethics opinions on cloud storage of client data. All of them permit it. All of them apply a reasonable-care standard. None of them treat the vendor's own marketing as a substitute for the lawyer's diligence.¹¹

THE DUE DILIGENCE FACTORS STATE BAR OPINIONS CONSISTENTLY ASK FOR

Consult someone with security expertise if you are not one yourself. Conduct diligence on the provider's security before you sign, not after. Confirm you retain ownership of and access to your data. Confirm confidentiality is protected contractually, not just as a marketing claim. Review periodically, because both the threat landscape and the vendor's terms change.¹¹

Set that standard against the data. In the ABA's 2024 Cloud Computing TechReport, fewer than 30 percent of responding attorneys reported reviewing ethics rules, privacy policies, or vendor terms of service. Only 23 percent evaluated the vendor's company history. Nearly 20 percent reported using no security precautions at all — while more than 93 percent rated vendor reputation as important.² The profession knows the standard. It is not meeting it.

The newest layer: generative AI

In July 2024 the ABA issued Formal Opinion 512, its first formal guidance on generative AI. Two of its holdings matter directly to software selection. First, the duty of confidentiality under Rule 1.6 applies to information a lawyer puts into a generative AI tool. Second — and this is the part that catches firms off guard — boilerplate engagement-letter language is not adequate consent for feeding client confidences into a self-learning AI tool. Informed client consent is required.¹⁰

That opinion arrived at exactly the moment the trust and estate software market began adding cloud AI features to existing products. Section 5 returns to what that means in practice.

Four Risks You Are Probably Not Managing

The following exposures are present in virtually every cloud-based trust administration deployment. They are not widely discussed because vendors have little incentive to raise them, and because most professional trustees have never had reason to read what their vendor's terms actually permit.

Risk 1 — Vendor personnel access you cannot audit

Most cloud vendors retain the ability for their own staff to access customer data for support, debugging, and product improvement. This is typically disclosed in terms of service that very few subscribers read. Support engineers, developers, and in some cases subcontractors may be able to view client trust data. A SOC 2 report does not prohibit this; it describes the controls around it.

Professional Insight: The vendor's privacy policy is not your engagement letter. Your clients agreed to hire you. They did not agree to have their financial lives readable by employees of a company they have never heard of, on a server you cannot audit.

Risk 2 — Legal process served on your vendor instead of on you

When data sits on third-party infrastructure it becomes reachable by legal process directed at the vendor, not only at you. Under the Stored Communications Act, content generally requires a warrant while non-content records can be reached by subpoena or court order.¹³ The CLOUD Act confirms that U.S. providers must produce data in their possession, custody, or control regardless of where in the world it is stored.¹⁴ Major providers publish policies committing to notify customers where legally permitted¹⁶ — but Section 2705(b) allows courts to prohibit that notice.¹³

Professional Insight: You cannot move to quash a subpoena you were never told about. The issue is not only whether data can ultimately be compelled — often it can be either way — but whether you get the chance to object and assert privilege before it is produced.

Risk 3 — Vendor failure on a timeline shorter than your retention duty

Software companies get acquired, sunset products, and shut down. Thomson Reuters discontinued its Firm Central practice management platform after September 2024, citing a crowded market; LexisNexis shut down Firm Manager in 2017 after a 2011 launch.¹⁷ The trust software market is consolidating right now: SS&C acquired Innovest Systems, Accutech rebranded as Cheetah, and Fi-Tek and BetaNXT launched a combined platform in 2025.¹⁸ When a product is retired, what happens to the data is governed by the vendor's terms, which typically provide a limited export window and then deletion — and which almost always place responsibility for records and backups on the customer.²⁹

Professional Insight: A trustee's obligation to preserve records runs for the life of the trust plus the limitations period for beneficiary claims — frequently a decade or more, and for dynasty trusts, generations. A typical SaaS commitment to data availability runs to the end of the notice period.

Risk 4 — The engagement letter gap

Most trustee engagement letters and client agreements were drafted before cloud software became the default. They address conflicts, fees, investment authority, and termination. They rarely address where client data is stored, who can access it, or what happens to it if the vendor fails. That silence is the exposure: not that something has gone wrong, but that the client was never given the information needed to consent to the arrangement.

Professional Insight: This is the cheapest of the four risks to fix and the one most often left unfixed. It requires a paragraph of disclosure and a documented decision, not new software.

"Secure Cloud" Is Not the Same as "Private"

The trust software market has converged on "bank-level security" and "SOC 2 compliance" as its reassurance of choice. These are meaningful attestations. They also answer a different question than the one a fiduciary needs answered.

SOC 2 is an AICPA attestation against the Trust Services Criteria. Only the Security criterion is mandatory; Availability, Processing Integrity, Confidentiality, and Privacy are optional and included at the vendor's election.¹⁹ A Type I report attests to the design of controls at a point in time. A Type II report attests to their operating effectiveness over a period.

Three limitations follow, and none of them are controversial among auditors:

- **The vendor selects the scope.** A SOC 2 report may not cover Confidentiality or Privacy at all. Asking whether a vendor "has SOC 2" without asking which criteria are in scope tells you very little.
- **It attests to controls, not outcomes.** Support access by vendor personnel is typically described and controlled in a SOC 2 report, not prohibited by it.
- **It does not touch legal process or business continuity.** A SOC 2 certified vendor is still subject to subpoena and can still be acquired and sunset.

The distinction is between security — are the vendor's controls sound against unauthorized access — and control — who has authorized access, and who decides. SOC 2 speaks to the first. A fiduciary's duty of confidentiality is mostly a question about the second.

Architecture, not diligence

	CLOUD (SOC 2)	LOCAL-FIRST
Protected against unauthorized external access	✓	✓
Data stored on hardware you own	✗	✓
Vendor personnel cannot read client data	✗	✓
Legal process must come to you, not your vendor	✗	✓
Records survive vendor failure or product sunset	✗	✓
Full function with no internet connection	✗	✓
Encryption key held only by the trustee	✗	✓

The comparison above describes architecture, not diligence. A careful cloud vendor with a well-scoped SOC 2 report may be a better choice than a careless local product. The point is that these rows are decided by where the data lives, and no amount of vendor diligence converts a red mark into a green one.

The Market Is Moving Toward More Exposure, Not Less

If you are waiting for the trust technology market to solve this on its own, the current direction of travel is worth knowing.

Trust operations technology has historically been a quiet corner of financial software — a short vendor list, long product lineages, nightly batch cycles, and replacement cycles measured in decades.¹⁸ That is changing on three fronts at once, and each front increases the exposures in Section 3 rather than reducing them.

Consolidation

SS&C — one of the most acquisitive companies in financial software — acquired Innovest Systems. Accutech, founded in 1987, rebranded as Cheetah in 2023. Fi-Tek and BetaNXT launched a combined trust and wealth platform in 2025.¹⁸ Every acquisition is a future migration, a future contract rewrite, and a future set of terms you did not agree to originally.

Cloud migration

Products that were once installed on a firm server are moving to hosted and browser-delivered models. That is a rational business decision for the vendors. It also means that fiduciaries who deliberately chose on-premise software years ago are being migrated into the cloud architecture described in Section 3 — sometimes as a routine upgrade, without a fresh disclosure conversation with clients.

AI features on top of cloud storage

A layer of AI-driven estate and trust platforms now sits above the traditional systems of record.¹⁸ These tools are genuinely useful. They are also, architecturally, a second copy of the most sensitive data in the file being sent somewhere else for processing — arriving in the same year the ABA held that boilerplate consent is insufficient for putting client confidences into a self-learning AI tool.¹⁰

This is not hypothetical

Two documented incidents are worth keeping in mind when a vendor adds an AI assistant to a product that already holds your client data.

- **Samsung, 2023.** Engineers pasted confidential source code and an internal meeting transcript into ChatGPT in three separate incidents within roughly twenty days. Samsung responded by banning employee use of generative AI tools on company devices.²⁰
- **OpenAI, March 2023.** A bug in a caching library exposed some users' chat titles and the first message of new conversations, along with payment-related data for 1.2 percent of ChatGPT Plus subscribers active during a nine-hour window.²¹ The exposure was not an attack. It was an ordinary software defect in a well-resourced company.

Note the distinction from the AI story most lawyers know. The sanctions in the Avianca matter were about fabricated citations — an accuracy and candor failure, not a data exposure. The two incidents above are confidentiality failures, and they are the relevant category here.

END OF PART ONE

Part One established the exposure and the authority behind it. Part Two turns to a single question: what does an architecture designed around these duties actually look like, and what does it not solve?

A Different Architecture

TrustArchive is a desktop application for trust administration built on a single premise: the trust record belongs on the fiduciary's machine, encrypted, under the fiduciary's control. The exposures in Part One are addressed at the architecture level rather than managed with policy.

How it is built

LAYER	IMPLEMENTATION	WHY THIS CHOICE
Application shell	Tauri, with a Rust backend and a standard HTML/CSS/JS front end	Smaller binary and attack surface than Electron. All cryptographic operations happen in the Rust backend, never in the interface layer.
Database	SQLCipher — encrypted SQLite — stored as a file on your machine	AES-256 page-level encryption with a unique IV per page, HMAC-SHA512 page authentication, and PBKDF2-HMAC-SHA512 key derivation over 256,000 iterations against a unique random salt. Built on peer-reviewed OpenSSL, not home-rolled cryptography. ²³
Key handling	Master password unlocks the database; the derived key is held in OS-native secure storage — Keychain or Credential Manager	The key never sits in a plaintext file and never leaves the machine.
Front to back end	Tauri IPC with explicit trust-boundary validation on every command	The interface is treated as untrusted input. Principle of least privilege between layers.
Network	No telemetry, no analytics, no background calls. The solo configuration makes no network calls at all.	Nothing to leak, because nothing is sent.

Being precise about what "no cloud" means

This is where most privacy-first software overstates, so the distinction is set out plainly.

CONFIGURATION	ACCURATE DESCRIPTION
Individual / solo	Fully offline. No network calls. No sync. Trust data never leaves the device.
Professional / practice / family office	Local-first with end-to-end encrypted sync between the firm's own machines. Records are encrypted on-device with AES-256-GCM before transmission. The sync infrastructure carries ciphertext only. TrustArchive cannot read your trust data — but sync does require an internet connection, and we will not describe a tier that syncs as "never touching the network."

Each machine runs a complete local encrypted database. Sync moves encrypted changes between machines you control; it is not a cloud system of record with a local cache. If the sync service were switched off tomorrow, every machine would still hold a complete, working, encrypted trust database.

Risk by Risk: What the Architecture Actually Changes

Part One set out four exposures. This is what each one looks like under a local-first architecture — including the parts that do not change.

RISK FROM PART ONE	UNDER A LOCAL-FIRST ARCHITECTURE
1. Vendor personnel access	Eliminated for the solo configuration and reduced to ciphertext for synced tiers. There is no readable copy of your trust data on any TrustArchive server, so there is no support-access control to trust, audit, or take on faith. We are not asking you to believe our staff will not look. There is nothing for our staff to look at.
2. Legal process	Changed, not eliminated. Your records can still be subpoenaed. What changes is that the subpoena must be served on you, the fiduciary, who can then assert privilege, object, move to quash, and notify the client. A vendor that holds no readable copy has nothing responsive to produce and cannot be compelled to hand over what it cannot decrypt.
3. Vendor failure	The database file is yours and sits on your disk. If TrustArchive ceased operating tomorrow, the last installed version continues to run offline and the data remains readable by that installation. Export to CSV and PDF is built in, not a retention-period courtesy. There is no server to shut off and no 30-day export window.
4. Engagement letter gap	Not solved by software. What changes is the disclosure you have to make. "Client trust records are maintained in an encrypted database on firm-controlled hardware; no third-party vendor has access to readable client data" is a materially easier paragraph to write, and to defend, than the alternative.

The claim we are not making

Local-first architecture does not make trust data unreachable, and this paper will not pretend otherwise. A trustee's own records are discoverable, subpoenaable, and subject to court order. Losing a laptop is a real risk that encryption at rest mitigates but does not erase. What the architecture does is remove an intermediary from the chain of custody — and put the fiduciary, rather than a software company, in the position of answering for the records.

That is the honest boundary of the argument. The value of a local-first architecture is not that it makes a fiduciary's records disappear. It is that it restores the ordinary chain of custody that trust law was written to assume: the trustee holds the records, the trustee answers for them, and no third party sits silently in the middle holding a readable copy the beneficiary was never told about.

Defensibility: The Fiduciary Record Itself

Privacy is only half of a fiduciary's technology problem. The other half is whether the record the software produces will hold up when a beneficiary challenges it or a court reviews it.

Double-entry, with principal and income separated at the transaction level

The fiduciary ledger maintains a full double-entry chart of accounts in which every account carries both a type — asset, liability, principal, income, expense, or distribution — and a category of principal or income. The separation is enforced in the data model, not reconstructed in a spreadsheet at year end.

That structure maps directly to the statutory framework trustees are actually judged against. The Uniform Principal and Income Act, and its successor the Uniform Fiduciary Income and Principal Act approved in 2018, govern how receipts and disbursements are allocated between principal and income and how a trustee may exercise the power to adjust. UFIPA adoption is still in progress across the states, so the allocation rules a trustee must follow vary by situs.²⁶ Ledger accounts are configured per trust, with the situs recorded on the trust itself.

Accountings in a format courts recognize

The National Fiduciary Accounting Standards and the associated Model Account format, developed by the profession and widely accepted across U.S. jurisdictions, are the reason a fiduciary accounting has a recognizable shape: a summary of purpose and content, then labeled schedules of receipts, disbursements, distributions, gains and losses, and assets on hand, with carrying value and current market value shown in parallel.²⁵ The standards require that an account be understandable to a person unfamiliar with fiduciary terminology.²⁵

TrustArchive captures the underlying data required for each schedule as transactions are entered, so producing an accounting is a reporting operation rather than a reconstruction project. Bank statements can be imported directly by CSV, OFX, QFX, or QBO, with per-account mapping profiles and auto-allocation rules that post recurring transactions to the correct principal or income account.

Multiple trusts, isolated properly

A single installation administers multiple trusts with records separated per trust rather than commingled and filtered. Each trust carries its own type, situs, and establishment date, and operator profiles control which users can read, write, export, or manage access on a trust-by-trust basis. Operator PINs are hashed with Argon2id derived from the master key.

WHY THIS BELONGS IN A PAPER ABOUT PRIVACY

A trustee who cannot produce a clean accounting has a problem that no amount of encryption fixes. The two halves are connected: the same local database that keeps the record private is the one that has to produce the record on demand. Software that is private but cannot generate a defensible account has solved the wrong half of the job.

The Cryptographic Audit Trail

Every fiduciary action in TrustArchive writes an entry to an append-only audit log. Each entry is hashed with SHA-256 over a canonical representation of its contents together with the hash of the entry before it, forming a chain from a genesis record forward.

The practical consequence is that the log is tamper-evident. Altering or deleting a past entry breaks the hash of every entry after it, and verification identifies precisely where the chain was broken.

Distributions, beneficiary changes, document executions, asset revaluations, and trust configuration updates are all captured.

Why this matters evidentially

Federal Rule of Evidence 902 was amended in 2017 to allow certain electronic records to be self-authenticating. Rule 902(13) covers a record generated by an electronic process or system that produces an accurate result, certified by a qualified person. Rule 902(14) covers data copied from an electronic device or file when authenticated by a process of digital identification — and the Advisory Committee note identifies hash-value comparison as the ordinary method for doing exactly that.²⁴

The audit log exports to CSV with a verification header that allows a third party — opposing counsel, a co-trustee, a court-appointed examiner — to recompute the chain independently, without TrustArchive software and without our involvement. That is the point. A verification that only the vendor can perform is not verification.

AN HONEST LIMIT ON THIS CLAIM

Rules 902(13) and 902(14) address authentication. They do not address hearsay. A trust accounting or audit export still requires a business-records foundation under Rule 803(6) to come in for its truth. A hash chain is strong evidence that a record has not been altered since it was written. It is not evidence that what was written was correct.

What the chain does and does not prove

THE AUDIT TRAIL PROVES	THE AUDIT TRAIL DOES NOT PROVE
That an entry exists and has not been modified since it was written	That the underlying fiduciary decision was prudent
The exact sequence in which actions were recorded	That the person who entered it had authority to act
Which operator profile recorded each action	That a transaction outside the system was also recorded in it
That no entry was silently removed from the history	That the values entered were accurate at the time

The distinction is deliberate. A tamper-evident record is a strong answer to the question "has this been altered?" and no answer at all to the question "was this the right decision?" TrustArchive is built to be authoritative on the first and to leave the second where it belongs — with the fiduciary's judgment and the professionals who advise it.

An Assistant That Never Phones Home

TrustArchive includes an AI assistant that answers questions about the trust in plain language: balances, distribution history, upcoming obligations, what a rule in the instrument requires. It runs entirely on the user's hardware through a local inference runtime. Prompts and trust data are never transmitted to an external API.

Set that against ABA Formal Opinion 512. The confidentiality concern the opinion identifies arises because a prompt containing client confidences is sent to a third party that may retain it, log it, or use it to train a model, and because boilerplate consent does not cover that.¹⁰ On-device inference does not manage that risk. It removes the transmission that creates it.

The honest caveat: downloading a model the first time requires an internet connection, and that download tells the model host which model was requested. It does not transmit trust data. For air-gapped deployments, models can be pre-cached before the machine is isolated. After that, inference runs offline indefinitely.

WHAT TO ASK ANY VENDOR ADDING AI TO YOUR TRUST SOFTWARE

Where does inference happen — on my device or on your servers? Are prompts logged, and for how long? Is my data used to train or improve your models, by default or by opt-out? Which subprocessors receive the prompt? And under Formal Opinion 512, what specific consent am I expected to obtain from my clients before using this feature? A vendor that cannot answer those five questions in writing has answered them.

Trust administration questions are, by their nature, the most sensitive things in the file. "Can I make a discretionary distribution to a beneficiary in a dispute with her siblings" is a query that contains the dispute, the beneficiary, and the trustee's thinking about it. A cloud assistant turns that into an API call and a log entry on someone else's infrastructure — a worse exposure than the underlying records, because it captures deliberation and not just data.

What Is In the Application

TrustArchive is a complete administration system, not a single-purpose accounting tool. The modules share one encrypted database and one audit trail.

MODULE	WHAT IT DOES
Multi-trust management	Administer multiple trusts from one installation with records isolated per trust, plus role-based operator access and per-trust permissions.
Fiduciary ledger	Double-entry accounting with principal and income separated at the transaction level, statement import with mapping profiles, auto-allocation rules, and ledger-based reporting.
Documents	Encrypted document storage with categorization, search, cryptographic sealing, and links to the assets, beneficiaries, and obligations each document governs.
Document generation	Template-driven creation of trust documents with local signature capture — no third-party e-signature service in the loop.
Beneficiaries	Beneficiary records, distribution tracking, obligations, and a complete interaction history per beneficiary.
Assets	Real property, financial accounts, precious metals, digital assets, and other holdings with valuation history, ownership documentation, and location of record.
Investments	Holdings, positions, and portfolio performance across trust accounts.
Obligations	Distribution requirements, accounting deadlines, and notice obligations tracked against due dates, with alerts on the overview dashboard.
Audit trail	SHA-256 hash-chained log of every fiduciary action, with independent third-party verification and CSV export.
Agent assistant	On-device AI for plain-language questions about the trust, its balances, and its rules.

What TrustArchive Does Not Do

A paper that asks you to read your vendor's terms carefully should be willing to state its own limitations in the same document. These are the trade-offs that come with this architecture.

There is no password recovery, by design

The master password derives the key that decrypts the database. We do not hold it, cannot reset it, and cannot recover your data if it is lost. That is the direct consequence of an architecture in which the vendor cannot read your data. It is a real operational burden and firms should treat master password custody as a documented internal control, not an afterthought.

Backup is your responsibility

A local database on a single machine is one hardware failure away from a very bad afternoon. Encrypted backup is straightforward — the database is a file — but it is a practice you have to adopt. Cloud software takes this problem off your hands; local-first software hands it back to you along with the control.

Synced tiers require an internet connection

Firm sync moves encrypted changes between your machines and needs a network to do it. We will not describe a syncing tier as fully offline. The solo configuration makes no network calls; the professional tiers make encrypted ones.

It does not give legal or tax advice

The rules engine applies the provisions you configure. The assistant answers questions about the data in your database. Neither interprets an ambiguous instrument, determines whether a discretionary distribution is prudent, or prepares a fiduciary income tax return. Those remain the professional's judgment.

It does not eliminate discovery

As Section 7 states: your own records remain subpoenaable and discoverable. The architecture changes who receives the request and who gets to object, not whether the records exist.

It is not a substitute for reviewing your engagement letter

Changing where your data lives changes what you should disclose. It does not update the disclosure for you, and it does not substitute for a review by ethics counsel in your jurisdiction.

WHY THIS SECTION EXISTS

Our brand standard is that we state facts and do not overclaim. If a limitation is real, we would rather you learn it here than after you have bought the software. A fiduciary evaluating a vendor should be suspicious of any product with no trade-offs, because the trade-offs are always there — the only question is whether the vendor told you about them.

What Professional Trustees Should Do Now

These four steps are worth taking regardless of what software you end up using. Three of them cost nothing but time.

- 1 Audit your current software stack.** List every platform that touches client trust data — practice management, accounting, document storage, e-signature, email, backup, and any embedded AI assistant. For each, locate the terms of service and privacy policy and answer three questions: who can access the data, under what circumstances, and what happens to it if the vendor ceases operations.²
- 2 Review your engagement letters.** Have your templates reviewed by ethics counsel for adequacy of data-storage disclosure. If you use any generative AI feature that transmits client information, review the consent language specifically against ABA Formal Opinion 512, which holds that boilerplate consent is not sufficient.¹⁰
- 3 Evaluate local-first alternatives.** Local-first software stores all data on hardware you control. There is no server-side copy of readable client data, no vendor access, and no cloud exposure. Whether it is the right answer depends on your firm size, backup discipline, and multi-user needs — but it should be on the list of options you considered.
- 4 Document your reasoning.** Whatever you choose, write down why you chose it and what diligence you performed. Fiduciary duty is not satisfied by a good outcome; it is satisfied by a deliberate, documented process. A one-page memo in the file is worth more than a vendor's security brochure.

Eight questions to put to any vendor, in writing

Ask these of your current provider and of anyone you evaluate, including us. Ask for written answers. The pattern of what a vendor will and will not put in writing is itself informative.

1. Where is my clients' data stored, and in what form — plaintext, encrypted at rest, or end-to-end encrypted?
2. Which of your employees or subcontractors can read customer data, under what circumstances, and is that access logged and reviewable by me?
3. Which SOC 2 Trust Services Criteria are in scope for your most recent report — Security only, or Confidentiality and Privacy as well?
4. What is your policy on notifying customers of subpoenas or legal process, and what happens when you are legally prohibited from notifying?
5. If you are acquired or discontinue this product, how long do I have to export, in what formats, and does export require an active paid account?
6. Do you use customer data to train or improve any model, by default or by opt-out?
7. If your AI features process client information, where does inference happen and how long are prompts retained?
8. Can a third party verify the integrity of my records without your software and without your involvement?

The Architecture of Accountability

Fiduciary duty is not satisfied by good intentions. It is satisfied by deliberate, documented choices that put the interests of beneficiaries first — including choices about how their most sensitive information is stored and protected.

The cloud software industry has made convenience its primary value proposition, and for most business applications convenience is the right priority. For trust administration — where the data involves family wealth, family conflict, incapacity, and legally enforceable obligations that outlive the people who created them — the calculus is different.

The exposures in Part One are not exotic. Vendor staff can read what vendors store. Subpoenas go where the data is. Software companies fail on shorter timelines than trusts run. Engagement letters written in 2016 do not describe what happened to the file in 2026. None of that requires a breach, a bad actor, or a worst case. It only requires time.

Professional trustees who take this seriously are not technophobes. They are fiduciaries. And the most defensible position — the one that requires no apology to a beneficiary, no explanation to a court, and no notification to a regulator — is the one where the data never left your control in the first place.



About TrustArchive

TrustArchive is fiduciary administration software that runs on your machine. Trust data — ledgers, documents, beneficiary records, assets, and audit trails — is stored in an encrypted local database. In the solo configuration nothing is transmitted at all. In firm configurations, records are encrypted on your device with AES-256-GCM before any transmission, so the sync infrastructure carries ciphertext only. We cannot read your trust data.

trustarchive.co · [Request a demonstration](#)

Encrypted. Local-first. Yours.

Notes and Sources

Sources are listed in the order first cited. Where a source reports an adoption count that changes over time — UTC, UFIPA, technology-competence, and state cloud-ethics opinions — verify the current figure before relying on it.

1. IBM, Cost of a Data Breach Report 2025 (20th ed., Ponemon Institute; 600 breached organizations, Mar 2024–Feb 2025). Global average USD 4.44M; U.S. average USD 10.22M, an all-time high; financial services USD 5.56M. ibm.com/reports/data-breach
2. American Bar Association, 2024 Cloud Computing TechReport (Legal Technology Survey Report, Mar 2025). ~75% use cloud computing for work; <30% review ethics rules, privacy policies, or vendor terms; 23% evaluated vendor company history; >93% rated vendor reputation important. americanbar.org
3. Uniform Trust Code (2000, last amended 2010), §§ 801, 802, 804, 807, 810, 813, 1005. Uniform Law Commission, uniformlaws.org
4. Restatement (Third) of Trusts § 78 cmt. (loyalty; confidentiality), § 82 (duty to furnish information), § 83 (clear and accurate accounts). American Law Institute, ali.org
5. Uniform Law Commission, UTC enactment map (36 states and D.C. as of 2024); see also ACTEC Foundation, "The Uniform Trust Code Turns 25" (2025).
6. ABA Model Rules of Professional Conduct: Rule 1.1 cmt. 8 (technology competence); Rule 1.6(c) (reasonable efforts against unauthorized disclosure); Rule 5.3 (nonlawyer assistance).
7. ABA Standing Committee on Ethics and Professional Responsibility, Formal Opinion 477R (2017), Securing Communication of Protected Client Information.
8. ABA Formal Opinion 483 (2018), Lawyers' Obligations After an Electronic Data Breach or Cyberattack.
9. ABA Formal Opinion 498 (2021), Virtual Practice.
10. ABA Formal Opinion 512 (Jul 29, 2024), Generative Artificial Intelligence Tools. Rule 1.6 applies to information input into generative AI tools; boilerplate engagement-letter consent is insufficient for self-learning tools; informed client consent is required. americanbar.org
11. ABA Legal Technology Resource Center, cloud ethics opinions chart (as compiled by Clio): 30 U.S. states have issued formal or informal ethics opinions on cloud use; all permit it under a reasonable-care standard. See also Florida Bar Ethics Opinion 12-3 (2013) and New York State Bar Opinion 1020.
12. R. Ambrogio, technology-competence adoption tracker (LawSites): 40 states plus D.C. and Puerto Rico have adopted the duty of technology competence; Puerto Rico Rule 1.19 effective Jan 1, 2026.
13. Stored Communications Act, 18 U.S.C. §§ 2701–2713 (Title II of ECPA), including § 2705(b) (orders prohibiting notice to the subscriber).
14. Clarifying Lawful Overseas Use of Data (CLOUD) Act, Pub. L. No. 115-141 (2018), amending the SCA to reach data in a provider's possession, custody, or control regardless of storage location.
15. U.S. Department of Justice, Seeking Enterprise Customer Data Held by Cloud Service Providers (Computer Crime and Intellectual Property Section guidance). justice.gov

REFERENCES (CONTINUED)

16. Amazon Web Services, CLOUD Act customer notification policy; Microsoft, "Our Practices" (blogs.microsoft.com/datalaw); Cloudflare Transparency Report. Each commits to notifying customers of legal process where legally permitted.
17. R. Ambrogio, "Thomson Reuters Is Shutting Down Its Firm Central Law Practice Management Software," LawSites (Feb 2024): support discontinued after Sep 30, 2024; LexisNexis Firm Manager launched 2011, shut down 2017. lawnext.com
18. P. Schaus, "Sector Spotlight: Trust Operations Technology for Banks and Trust Companies," CCG Catalyst (Aug 19, 2026): short vendor lists and decade-long replacement cycles; SS&C acquisition of Innovest Systems; Accutech rebranded as Cheetah (2023); Fi-Tek and BetaNXT launched TrustWealthX (2025); AI-driven estate platforms layered above systems of record. ccgcatalyst.com
19. AICPA, Trust Services Criteria (TSP Section 100; 2017 criteria, points of focus revised 2022). Security is the only mandatory criterion; Availability, Processing Integrity, Confidentiality, and Privacy are elected by the service organization.
20. M. Gurman, "Samsung Bans Staff's AI Use After Spotting ChatGPT Data Leak," Bloomberg (May 2, 2023); see also AI Incident Database Incident 768.
21. OpenAI, "March 20 ChatGPT outage: Here's what happened" (2023): a Redis client library bug exposed some users' chat titles and first messages, and payment-related data for 1.2% of ChatGPT Plus subscribers active in a nine-hour window. openai.com
22. OpenAI, Enterprise Privacy documentation: API, Enterprise, Team, and Edu data are not used for training by default; consumer ChatGPT historically could use inputs for training absent opt-out. openai.com/enterprise-privacy
23. Zetetic LLC, SQLCipher Design: 256-bit AES in CBC mode, per-page encryption with a unique random IV per page, HMAC-SHA512 page authentication, PBKDF2-HMAC-SHA512 key derivation with a unique 16-byte random salt and 256,000 default iterations, built on OpenSSL libcrypto. zetetic.net/sqlcipher/design
24. Fed. R. Evid. 901; 902(13)–(14) (effective Dec 1, 2017) and Advisory Committee Notes, identifying hash-value comparison as the ordinary method of digital identification. Authentication only; a hearsay exception such as Fed. R. Evid. 803(6) remains separately required.
25. Committee on National Fiduciary Accounting Standards, Uniform Fiduciary Accounting Principles and Model Account Formats (1975; 1984 rev.), widely accepted across U.S. jurisdictions; see also ACTEC Law Journal commentary.
26. Uniform Fiduciary Income and Principal Act (UFIPA), approved by the ULC in Jul 2018, successor to the Uniform Principal and Income Act (1997, amended 2000). Adoption in progress; Florida became the eighth enacting state effective Jan 1, 2025, joining Arkansas, California, Colorado, Kansas, Utah, Virginia, and Washington. Verify current adoption against the ULC.
27. Uniform Trust Code § 1005 (limitation of action against trustee following a report adequately disclosing a potential claim); confirm the applicable period under the enacting state's statute.
28. Cerulli Associates, projection of approximately USD 124 trillion in wealth transfer through 2048, as reported in CCG Catalyst (Aug 2026).
29. Typical SaaS post-termination data terms: Turley Law, "SaaS Data Ownership and Exit Strategy"; Pillsbury Winthrop Shaw Pittman, "Lessons from a Major Software Sunsetting." Vendor terms commonly place responsibility for records and backups on the customer and provide a limited export window before deletion.

Disclaimer

This white paper is published by TrustArchive for general informational purposes. It is not legal, tax, or professional advice, and it does not create any attorney-client or advisory relationship. The legal authorities summarized here are stated generally; trust law, rules of professional conduct, and ethics opinions vary by jurisdiction and change over time.

Statutory adoption counts, ethics opinions, and reported figures are current as of publication and should be verified before being relied upon. Nothing in this paper should be read as a statement that any particular software product, vendor, or practice does or does not comply with any legal or ethical obligation, or that any trustee has breached a duty. Professional trustees should consult qualified counsel in their own jurisdiction before making decisions about client data handling, engagement letter disclosure, or vendor selection.

TrustArchive is a product of ClevrCFO LLC. Product capabilities described in Part Two reflect the application as of publication and are subject to change. Security claims are stated by configuration tier; see Section 6 for the distinction between the offline solo configuration and end-to-end encrypted firm sync.



TrustArchive
Encrypted. Local-first. Yours.

© 2026 TrustArchive · trustarchive.co